

Cross-Site Scripting (XSS) in hub's web interface #8259

✓ Closed



mleblebici opened on Apr 29, 2020



📄 Bug Report

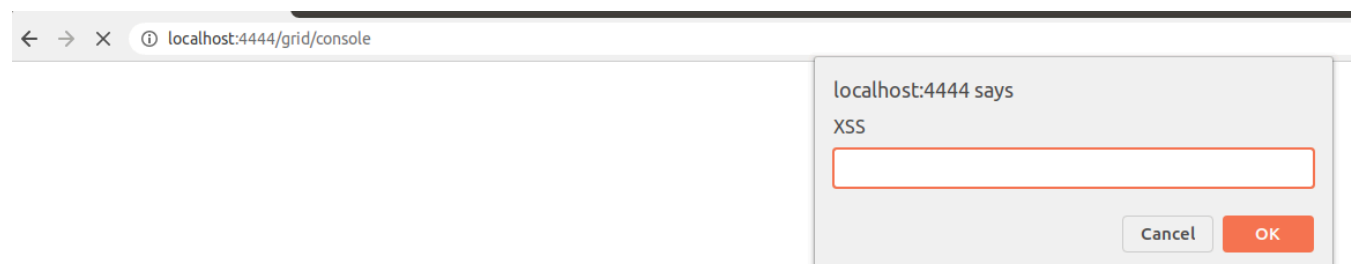
A cross-site scripting (XSS) vulnerability exists in Selenium Grid hub's web interface. The vulnerability is located in /grid/console page where unvalidated user input from node's configuration is displayed back to the users.

To Reproduce

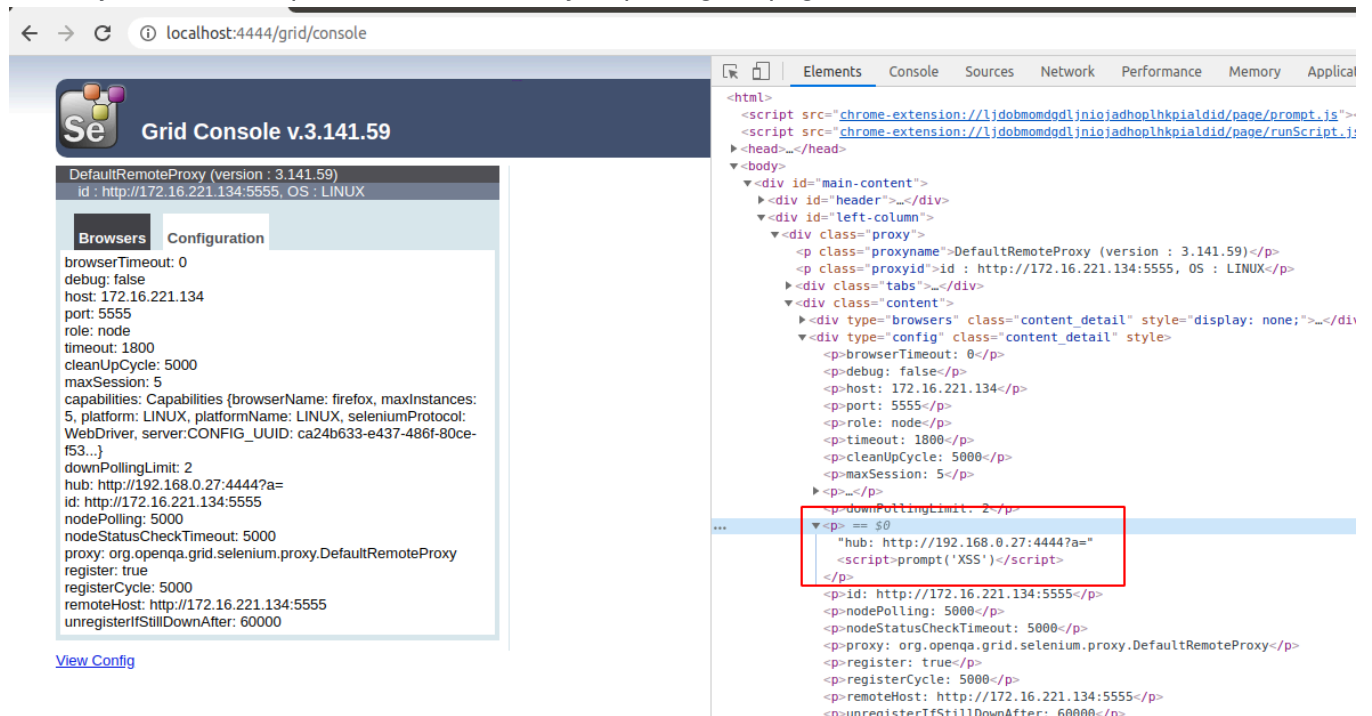
A node can register to a hub using the following configuration file, where an XSS payload is given in the hub parameter. Since the payload is written as a URL GET parameter value, the node is still be able to register to the hub.

```
root@kali: ~/Desktop/selenium$ cat node.json
{
  "capabilities":
  [
    {
      "browserName": "firefox",
      "maxInstances": 5,
      "seleniumProtocol": "WebDriver"
    }
  ],
  "maxSession": 5,
  "port": 5555,
  "register": true,
  "registerCycle": 5000,
  "hub": "http://192.168.0.27:4444?a=<script>prompt('XSS')</script>",
  "nodeStatusCheckTimeout": 5000,
  "nodePolling": 5000,
  "role": "node",
  "unregisterIfStillDownAfter": 60000,
  "downPollingLimit": 2,
  "debug": true,
  "servlets": [],
  "withoutServlets": [],
  "custom": {}
}
```

Once the hub's web interface is opened, injected JavaScript code is executed on the user's browser, as shown below.



Also, injected JavaScript code can be seen by inspecting the page source.



Expected behavior

The contents of configuration file should be encoded before being displayed to users.

Environment

The vulnerability exists regardless of the environment.

The test is done using Selenium Grid v3.141.59.

 ghost added **A-needs-triaging** on Apr 29, 2020

 AutomatedTester added **B-grid** and removed **A-needs-triaging** on Apr 30, 2020

 diemol on May 23, 2020

Member ...

Thank you for reporting this [@mleblebici](#), nevertheless, we need to close this because:

- Grid 3.x is not under development anymore, the code is not even present in the tree.
- Grid 4 will have a different UI and we will double-check this issue is not happening.
- Whenever someone deploys a Grid, it should be done in its own environment under restricted network permissions.

 diemol closed this as **completed** on May 23, 2020

 lock bot on Jun 25, 2020

This thread has been automatically locked since there has not been any recent activity after it was closed. Please open a new issue for related bugs.



lock locked and limited conversation to collaborators [on Jun 25, 2020](#)

[Sign up for free](#)

to join this conversation on GitHub. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

B-grid

Type

No type

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development



Code with agent mode



No branches or pull requests

Participants



